Web Application Penetration Testing Report

Authentication Bypass via SQL Injection

---

1. Executive Summary

A web application penetration test was conducted in a controlled lab environment to evaluate the authentication mechanism of the login functionality. During the assessment, a SQL Injection vulnerability was identified in the username parameter, which allowed authentication bypass without valid credentials. The vulnerability was identified using both automated testing (Burp Suite Intruder) and manual validation (Burp Suite Repeater). Due to the impact on authentication controls, this vulnerability is classified as High severity.

2. Scope

• Target Component: Login Functionality
• Parameters Tested: username, password
• Testing Approach: Black-Box Testing
• Environment: Controlled Security Lab

3. Methodology

The assessment followed CEH-aligned testing methodology:

Phase 1: Request Interception and Analysis
- Intercepted login request using proxy.
- Analyzed parameters for backend interaction.

Phase 2: Manual Injection Testing
- Inserted SQL injection payloads manually.
- Observed response variations and authentication behavior.

Phase 3: Automated Testing
- Sent request to Intruder.
- Marked username as injection point.
- Executed Sniper attack using SQL payload list.

Phase 4: Manual Validation
- Reproduced successful payload in Repeater.
- Confirmed authenticated session issuance.

4. Finding: Authentication Bypass via SQL Injection

Severity: High
Affected Parameter: username
Attack Vector: Remote (Unauthenticated)

Description:
The application fails to properly sanitize user input before embedding it into backend SQL queries. This allows manipulation of query logic, resulting in authentication bypass.

5. Proof of Concept

1. Intercept login request.
2. Modify username parameter with crafted SQL payload.
3. Replay request.
4. Application grants access without valid credentials.
5. Authenticated session cookie issued and dashboard accessible.

6. Risk Rating

Confidentiality Impact: High
Integrity Impact: High
Availability Impact: Low
Overall Severity: High

7. Impact

• Unauthorized access to user accounts
• Potential administrative compromise
• Exposure of sensitive data
• Risk of further database exploitation

8. Remediation

• Implement parameterized queries (Prepared Statements).
• Avoid dynamic SQL concatenation.
• Apply strict server-side input validation.
• Enforce least-privilege database permissions.
• Conduct regular security testing and code reviews.

9. Conclusion

The penetration test identified a high-severity SQL Injection vulnerability in the authentication mechanism.
The vulnerability was confirmed through automated detection and manual validation.

Immediate remediation is recommended to prevent unauthorized system access.